

M-TRAVEL TOURS & TRAVEL MARKETPLACE

Unified Travel, Mobility & Safari Ecosystem for Kenya — Executive Client Dossier

Target Market: Kenya & East Africa	Payment Gateway: Safaricom M-Pesa (Daraja 2.0)	Security Standard: JWT + RBAC + DB RLS
Key Contact: Amos (0722374535)	Head Office: 0207855558	Email: safari@jambo.africa

1. Executive Summary & Platform Purpose

M-TRAVEL is a state-of-the-art travel and mobility platform engineered to unify Kenya's fragmented travel industry. It provides a seamless, one-stop digital marketplace that connects individual travelers, corporate clients, and international tourists with verified asset owners and licensed travel operators.

The platform eliminates booking friction through automated **Lipa Na M-Pesa STK Push** payments, multi-currency pricing (KES, USD, EUR, GBP), an escrow-style digital wallet for automated owner payouts, and an interactive **3D Route Network Globe**. Whether hiring a 4x4 safari cruiser, reserving an executive bus seat, booking a multi-day wildlife expedition, or securing a beachfront villa, M-Travel delivers end-to-end reliability, transparency, and safety.

2. Core Marketplace Verticals & Key Capabilities

Vertical	Platform Features & Capabilities	Target Audience
■ Vehicle Rentals & Safari Fleets	- Safari 4x4 Land Cruisers with pop-up roofs, VIP Toyota Alphards & Sedans - Real-time date availability calendar, Haversine GPS proximity search - Dynamic daily/km rate computation, optional chauffeur, and insurance verification	Tourists, corporate executives & fleet owners
■ Bus & Shuttle Reservations	- Scheduled inter-county coach network (Nairobi, Mombasa, Kisumu, Nakuru) - Interactive seat layout selector, instant digital QR-code boarding passes - Carrier departure schedules, bus station tracking, and multi-class ticketing	Commuters, inter-county travelers & bus companies
■ Curated Safari & Holiday Tours	- Multi-day curated expeditions (Maasai Mara, Amboseli, Diani Beach, Mt. Kenya) - Verified Tour Operator credentials, detailed day-by-day itineraries - Transparent pricing breakdowns (park entry, luxury tented camps, game drives)	International tourists, safari enthusiasts & tour guides
■ Holiday Homes & Luxury Stays	- Oceanfront villas, private bush cottages, and luxury serviced city apartments - County filters, bedroom/guest quotas, verified amenities (pool, chef, Wi-Fi) - Direct reservation confirmation, host messaging, and check-in assistance	Vacationing families, group retreats & property hosts
■ Native M-Pesa & Digital Wallet	- Instant Lipa Na M-Pesa STK Push integration via Safaricom Daraja API - Double-entry digital wallet ledger for automated customer deposits & refunds - Automated B2C M-Pesa/Bank payout disbursements for partner owners	All platform clients, asset owners & finance admins

3. Multi-Stakeholder Portals & User Workflows

M-Travel features specialized, role-tailored dashboards to streamline interactions between all market participants:

Stakeholder Portal	Operational Workflow & Features
Traveler & Tourist Hub	- Comprehensive catalog search across all 4 verticals with live multi-currency switcher - Live booking tracking, printable digital QR-tickets, one-click cancellation with policy enforcement - Verified post-trip reviews and rating system; personal wallet management for top-ups & refunds
Vehicle Owner & Host Dashboard	- Asset onboarding: publish vehicle/property profiles with high-res galleries and spec sheets - Real-time booking request management (Accept/Reject) with automatic customer push alerts - Revenue analytics, transaction history, and instant M-Pesa B2C wallet payout withdrawals
Bus Operator & Tour Partner Portal	- Route creation, departure scheduling, seat inventory management, and passenger manifests - Publishing customizable tour packages, pricing per pax, and itinerary management
Admin & Super-Admin Console	- System-wide oversight: user management, vehicle approvals, and anti-fraud stolen vehicle registry - Financial transaction ledger audits, coupon & discount management, and support ticket desk

4. Comprehensive Security Enforcement Framework

Security in M-Travel is built on a **defense-in-depth** philosophy, implementing rigorous safeguards across every layer of the architecture — from the client browser and API gateway to the application logic and database engine:

4.1. Identity, Authentication & Token Security

- Dual-Token Architecture (JWT):** Separates authentication into short-lived access tokens (15 minutes) and long-lived refresh tokens (7 days), drastically reducing the attack window in case of token interception.
 - Cryptographic Refresh Token Rotation:** Refresh tokens are never stored as plain text. They are hashed using high-entropy salted cryptography (`tokenHash``) in PostgreSQL. Upon renewal, the old token is automatically revoked and rotated, preventing replay attacks.
 - High-Entropy Password Hashing:** Passwords are protected using salted Argon2 / Bcrypt algorithms with 12 calculation rounds, making them resilient to rainbow-table and brute-force attacks.
 - Device Footprint & Session Auditing:** The system monitors active sessions via the ``device_logins`` table, logging IP addresses, User-Agents, and geolocation data to detect suspicious login patterns.

4.2. Role-Based Access Control (RBAC) & Ownership Enforcement

- Granular Role Separation:** NestJS guards (``@Roles(`` and ``RolesGuard``) strictly restrict access across 8 specific roles: ``TRAVELER``, ``TOURIST``, ``VEHICLE_OWNER``, ``BUS_COMPANY``, ``TOUR_OPERATOR``, ``HOME_OWNER``, ``ADMIN``, and ``SUPER_ADMIN``.
 - Strict Resource Ownership Verification:** Endpoints verify that the authenticated ``request.user.id`` strictly owns the target resource before allowing state modifications (e.g., only the vehicle owner can accept a booking; only the traveler can cancel their reservation).
 - Privilege Escalation Prevention:** Administrative actions (approvals, ledger overrides) are restricted to verified ``ADMIN`` accounts.

4.3. Database Row-Level Security (RLS) & Relational Integrity

- PostgreSQL Row-Level Security:** RLS policies are enforced across all core tables (``wallets``, ``payments``, ``bookings``, ``transactions``, ``vehicle_alerts``, ``audit_logs``), preventing unauthorized data querying even if an application leak occurs.
 - Referential Integrity:** Strict foreign key constraints with explicit cascading policies (``ON DELETE CASCADE`` / ``ON DELETE SET NULL``) prevent orphaned records and maintain data consistency.

4.4. API Gateway, Network Hardening & Anti-Abuse

- **HTTP Security Headers (Helmet):** Protects against Cross-Site Scripting (XSS), Clickjacking, MIME-type sniffing, and Cross-Site Request Forgery (CSRF).
- **Global Rate Limiting & Throttling:** ``ThrottlerGuard`` enforces a rate limit (100 requests per 60 seconds per client IP) to block Distributed Denial of Service (DDoS) attempts, automated scraping, and credential stuffing.
- **Mass-Assignment & Schema Validation:** Strict NestJS ``ValidationPipe`` with ``whitelist: true`` and ``forbidNonWhitelisted: true`` automatically rejects unapproved payload parameters, preventing parameter tampering and prototype pollution.
- **Centralized Exception Shielding:** An ``AllExceptionsFilter`` intercepts unhandled runtime exceptions, sanitizing output so internal database errors and stack traces are never exposed to clients.

4.5. Financial Grade Payment Security & Anti-Fraud

- **Safaricom Daraja 2.0 Security:** End-to-end encrypted OAuth 2.0 Client Credentials flow over TLS/HTTPS with dynamically generated Base64 passwords and cryptographic timestamping.
- **Double-Spending Protection & Ledger Auditing:** All wallet movements are recorded in an append-only transaction ledger (``transactions`` table). Wallets cannot be modified without an immutable reference ID.
- **Anti-Fraud Vehicle Alert System:** Includes a dedicated stolen vehicle registry (``vehicle_alerts`` table and ``is_stolen`` flags) that automatically locks flagged vehicles from being booked.

5. Technology Stack & Enterprise Specifications

Architecture Layer	Technology / Framework	Enterprise Capabilities
Backend API	NestJS, TypeScript, Prisma ORM, Swagger OpenAPI	Enterprise modular design, strict DTO validation, self-documenting REST endpoints.
Database	PostgreSQL / Supabase, Row-Level Security, UUIDs	ACID compliance, bank-grade encryption at rest, high-speed relational queries.
Frontend Client	React 18, Vite, TypeScript, TailwindCSS, Framer Motion	Ultra-fast load times (<1s), responsive mobile-first UI, fluid animations.
3D Visual Globe	React Three Fiber, Three.js 3D Route Network	Signature interactive 3D globe visualizing East Africa travel routes.
Mobile Payments	Safaricom Daraja 2.0 (Lipa Na M-Pesa STK, B2C)	Instant mobile money checkout with automated partner payout processing.

Client Presentation Summary & Next Steps:
M-Travel delivers a complete, production-ready travel marketplace that unites vehicle hire, bus ticketing, safari tours, and vacation stays with native M-Pesa payments. Backed by institutional-grade cybersecurity (JWT token rotation, RBAC, database RLS, and encrypted financial ledgers), the platform is ready for rapid enterprise scaling, investor demonstrations, and nationwide commercial rollout.